

המשוואה הקלאסית להערכת סיכוני אבטחת מידע

הנושא נוגע בלב ליבו של תחום אבטחת המידע (Cybersecurity) וניהול סיכונים ארגוני בכלל. המשוואה שצינת היא כלי העבודה הבסיסי והחשוב ביותר שיש למנהלי אבטחת מידע (CISOs) כדי לקבל החלטות.

בעולם שבו המשאבים (זמן, כסף, כוח אדם) תמיד מוגבלים, והאיומים הם אינסופיים, ארגון לא יכול להגן על הכל באותה רמת דחיפות. המשוואה הזו עוזרת לנו לענות על השאלה: **במה עלינו לטפל קודם?**

בוא נפרק את המשוואה לגורמים שלה ונבין את ההיגיון שעומד מאחוריה.

המשוואה הקלאסית היא:

חומרת הסיכון (Risk Severity) = סבירות (Likelihood) × השפעה/נזק (Impact)

(הערה: לעיתים משתמשים במילה "נזק" ולעיתים במילה "השפעה". באנגלית זה Impact. הכוונה זהה – גודל הפגיעה).

1. המרכיב הראשון: סבירות (Likelihood / Probability)

הגדרה: הסבירות היא ההסתברות שאירוע אבטחה מסוים אכן יתרחש בפועל.

במילים פשוטות: "מה הסיכוי שזה יקרה?"

הסבירות נקבעת על בסיס שילוב של שני גורמים:

- **האיום (Threat):** האם יש מישהו שם בחוץ (האקר, עובד ממורמר, או אפילו אסון טבע) שיש לו מוטיבציה ויכולת לגרום נזק?
- **החולשה (Vulnerability):** האם יש לנו "חור" בהגנה (באג בתוכנה, סיסמה חלשה, דלת לא נעולה בחדר שרתים) שהאיום יכול לנצל?

איך מודדים סבירות?

לרוב לא מדובר במספרים מדויקים (כמו 42.5%), אלא בהערכות איכותיות:

- **גבוהה (High):** קורה כל הזמן, או צפוי לקרות בקרוב מאוד (למשל: עובדים שמקבלים מיילים של פשינג).
- **בינונית (Medium):** עלול לקרות, כבר קרו מקרים דומים בעבר.
- **נמוכה (Low):** מאוד לא סביר שיקרה, דורש צירוף מקרים נדיר או יכולות תקיפה מדינתיות (למשל: מטאוריט שפוגע בחדר השרתים, או תקיפת סייבר מתוכננת מאוד על עסק קטן שאין בו מידע רגיש).

2. המרכיב השני: השפעה / נזק (Impact)

הגדרה: ההשפעה היא גודל הפגיעה בארגון במידה והאירוע אכן התרחש.

במילים פשוטות: "אם זה קורה, כמה חזק זה יכאב לנו?"

הנזק לא נמדד רק בכסף ישיר, אלא כולל היבטים שונים:

- **פגיעה כלכלית:** הפסד הכנסות ישיר, עלויות התאוששות, קנסות רגולטוריים.
- **פגיעה תפעולית:** השבתת מערכות, חוסר יכולת לייצר או לתת שירות.
- **פגיעה במוניטין:** אובדן אמון לקוחות, פרסום שלילי בתקשורת.
- **פגיעה משפטית:** תביעות מצד לקוחות או ספקים.
- **פגיעה בחיי אדם:** (רלוונטי במיוחד בבתי חולים או תשתיות קריטיות).

איך מודדים השפעה?

גם כאן, לרוב משתמשים בהערכות איכותיות:

- **גבוהה (High):** השבתה מוחלטת של הארגון, פשיטת רגל, סכנת חיים.
- **בינונית (Medium):** פגיעה מורגשת בפעילות, הפסד כספי משמעותי אך נסבל.
- **נמוכה (Low):** אי נוחות קלה, נזק כספי זניח שקל לתקן.

3. התוצאה: חומרת הסיכון (Risk Severity) – למה כופלים?

הסיבה שאנחנו מבצעים פעולת כפל (רעיונית) בין שני הגורמים היא כדי לקבל תמונה אמיתית של הדחיפות. אם נסתכל רק על אחד מהם, נקבל תמונה מעוותת.

הנה ארבע דוגמאות קיצון שמסבירות את ההיגיון של המכפלה:

תרחיש א': סבירות גבוהה X נזק גבוה = סיכון קריטי (לטפל מיד!)

- **דוגמה:** שרת ראשי של החברה חשוף לאינטרנט ללא סיסמה (סבירות גבוהה מאוד שיפרץ), ואם הוא נפרץ כל המידע של הלקוחות נגנב (נזק עצום).
- **התוצאה:** זה הדבר הראשון שצריך לתקן הבוקר.

תרחיש ב': סבירות נמוכה X נזק נמוך = סיכון זניח (אפשר להתעלם)

- **דוגמה:** הסיכוי שמשהו יגנוב עכבר מחשב ישן ממחסן ציוד (סבירות נמוכה כי המחסן נעול), והנזק הוא עלות של 20 ש"ח (נזק נמוך).
- **התוצאה:** לא משקיעים בזה שום משאב הגנה.

תרחיש ג': סבירות גבוהה X נזק נמוך = סיכון בינוני

- **דוגמה:** עובד ששוכח את הסיסמה שלו למערכת לא קריטית כל שבועיים (סבירות גבוהה), הנזק הוא 10 דקות עבודה של איש IT שמאפס לו סיסמה (נזק תפעולי נמוך).

- **התוצאה:** זה מציק ועולה קצת כסף, אולי ננסה לשפר הדרכה, אבל זה לא ישבית את החברה.

תרחיש ד': סבירות נמוכה מאוד X נזק עצום = סיכון "ברבור שחור" (דורש היערכות מיוחדת)

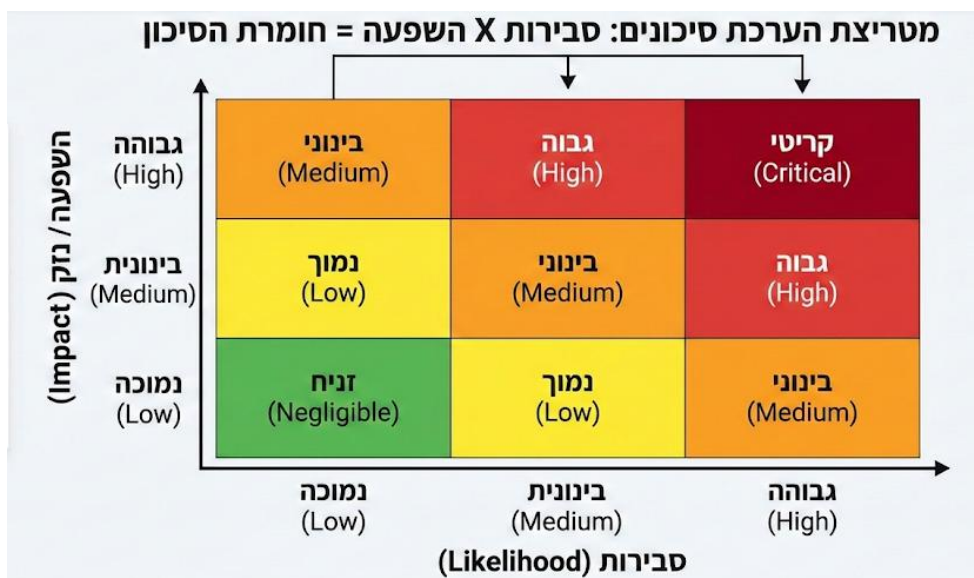
- **דוגמה:** שריפת ענק שתשמיד את כל משרדי החברה והשרתים (סבירות נמוכה מאוד אם יש גלאי עשן), אבל אם זה קורה – אין חברה (נזק קריטי).
- **התוצאה:** אי אפשר למנוע לחלוטין, אז מטפלים בזה באמצעות ביטוח ותוכנית התאוששות מאסון (DRP), ולא בהכרח ע"י הוספת עוד ועוד מטפים.

סיכום

המשוואה **סבירות X נזק = חומרת הסיכון** היא הכלי שמאפשר לנו לקחת רשימה של 100 בעיות אבטחה פוטנציאליות, ולדרג אותן מהדחופה ביותר (שילוב של סבירות גבוהה ונזק גבוה) ועד לזניחה ביותר. היא הופכת תחושות בטן ושמעויות למודל עבודה מסודר שמאפשר קבלת החלטות ניהוליות והקצאת תקציבים חכמה.

דוגמה מעשית

המטריצה שבתמונה היא הכלי הפרקטי שהופך את המשוואה התיאורטית (סבירות X נזק) למפת דרכים ברורה לפעולה. היא עוזרת לכם לקחת רשימה ארוכה של איומים ולתעדף אותם ויזואלית.



הנה מדריך צעד-אחר-צעד כיצד להשתמש במטריצה הזו בתהליך הערכת סיכונים (Risk Assessment):

שלב מקדים: הכנת רשימת הסיכונים

לפני שניגשים למטריצה, עליכם לזהות את הסיכונים הרלוונטיים לארגון שלכם. לדוגמה: "פריצת סייבר למאגר הלקוחות", "עובד שולח בטעות מידע רגיש במייל", "שרת קריטי קורס בגלל תקלת חומרה".

תהליך השימוש במטריצה (עבור כל סיכון בנפרד)

קחו סיכון אחד מרשימת הסיכונים שלכם, ובצעו את השלבים הבאים:

1. הערכת הסבירות (Likelihood) - הציר האופקי למטה

הסתכלו על הציר התחתון של המטריצה. עליכם לשאול: "מה הסיכוי שהאירוע הזה יתממש בפועל?" בחרו אחת משלוש האפשרויות:

- **גבוהה (High):** כמעט בטוח שיקרה, קורה לעיתים תכופות, או שהאיום מידי וממשי (למשל: ניסיונות פשינג יומיים).
- **בינונית (Medium):** ייתכן שיקרה, קרה בעבר בארגון או בארגונים דומים.
- **נמוכה (Low):** לא סביר שיקרה, נדיר מאוד (למשל: אסון טבע חריג באזור לא מועד).

2. הערכת ההשפעה/נזק (Impact) - הציר האנכי משמאל

הסתכלו על הציר השמאלי של המטריצה. עליכם לשאול: "אם האירוע הזה קורה מחר בבוקר, כמה קשה תהיה הפגיעה בארגון?" (כלכלית, תפעולית, תדמיתית).

בחרו אחת משלוש האפשרויות:

- **גבוהה (High):** נזק קריטי. השבתת הארגון, הפסד כספי עצום, פגיעה בלתי הפיכה במוניטין, סכנת חיים.
- **בינונית (Medium):** נזק משמעותי אך נסבל. פגיעה זמנית בשירות, הפסד כספי מורגש אך לא כזה שימוטט את החברה.
- **נמוכה (Low):** נזק מינורי. אי נוחות קלה, עלות תיקון זניחה.

3. מציאת חומרת הסיכון (Risk Severity) - המפגש במטריצה

כעת, הצליבו את שתי הבחירות שלכם בתוך הטבלה. המשבצת שבה נפגשים הטור (סבירות) והשורה (השפעה) שבחרתם, היא התוצאה הסופית – חומרת הסיכון.

דוגמה מעשית לשימוש:

נניח שהסיכון הוא: "גניבת מחשב נייד של איש מכירות (שאינו מוצפן)".

1. **סבירות:** אנשי מכירות מסתובבים הרבה בחוץ, בבתי קפה וברכבות. הסיכוי לאובדן או גניבה הוא ריאלי מאוד נבחר **בינונית (Medium)** בציר התחתון.
2. **השפעה:** המחשב לא מוצפן ומכיל רשימת לקוחות רגישה ומחירונים. אם המידע דולף למתחרים, הנזק העסקי גדול מאוד - נבחר **גבוהה (High)** בציר השמאלי.
3. **הצלבה:** אם נלך בטור "סבירות בינונית" כלפי מעלה, ובשורת "השפעה גבוהה" ימינה, ניפגש במשבצת האדומה: **סיכון גבוה (High)**.

מה עושים עם התוצאות? (משמעות הצבעים)

הצבעים והתגיות במטריצה מכתיבים את דחיפות ואופי הטיפול הנדרש:

- **בורדו - קריטי (Critical):** מצב חירום. סיכון בלתי קביל שדורש טיפול מיידי ועצירת פעילות אם צריך עד לתיקונו. זהו "Showstopper".
- **אדום - גבוה (High):** דחיפות גבוהה. יש להכין תוכנית טיפול (Mitigation Plan) ולהקצות משאבים לטיפול בסיכון זה בטווח הזמן הקרוב מאוד.
- **כתום - בינוני (Medium):** סיכון שיש לנהל. יש להכניס אותו לתוכנית העבודה השנתית/רבעונית ולשקול פתרונות אבטחה, אך לא בבהילות.
- **צהוב - נמוך (Low):** סיכון נסבל. לרוב נסתפק בבקורות הקיימות ונבצע ניטור תקופתי לוודא שהמצב לא מחמיר.

- **ירוק - זניח (Negligible):** "לקבל את הסיכון". עלות הטיפול בסיכון כנראה גבוהה יותר מהנזק האפשרי. אין צורך בפעולה אקטיבית.

טיפ חשוב להצלחה

מכיוון שהגדרות כמו "בינוני" או "גבוה" הן סובייקטיביות, מומלץ מאוד לבצע את תהליך הדירוג במטריצה **כצוות** (למשל: מנהל אבטחת מידע, מנהל IT, ומנהל מהצד העסקי/תפעולי). הדיון המשותף עוזר להגיע להערכה מדויקת יותר של המציאות.